

ReMEETs（再会のボトルメール）

全監査・実装統合マスター完了報告書（商用公開適格性判定書）

文書タイトル	ReMEETs 全監査・実装 統合マスター完了報告書	報告書発行日	2026年9月4日
サービス制定・施行日	2026年8月15日	総合適合判定	 88 / 88 項目 100% 完全合格 (PASS)
監査対象バージョン	v1.2.4-RELEASE (Commit: cc263cc)	検証エンジン	ReMEETs Automated Master Audit Engine

総合監査総括サマリー

本報告書は、日本の思い出と再会を紡ぐボトルメールプラットフォーム「ReMEETs」における、セキュリティ・個人情報保護・決済保全・負荷耐性・警察令状照会・法的表記・PWA/SEO拡張に至る全88項目の検証結果を公式に証明するものです。すべての脆弱性対策と認可制御が解決され、商用サービスとして求められる最高水準の安全防衛体制が確立されていることを認定します。

1. セキュリティ&プライバシー監査（全26項目 100% 解決）

ID	カテゴリ	点検・監査項目	リスク	判定	対策・解決内容
SEC-001	個人情報保護	クイズ正解平文データの通信露出遮断	高	解決済	APIレスポンスから平文答えを物理削除
SEC-002	認可制御	解決済み手紙の第三者への個人情報漏洩遮断	高	解決済	第三者には本文・LINE IDを完全非開示
SEC-003	エンドポイント	認証なしデバッグAPI (/post_questions) の封鎖	高	解決済	管理者権限 (isAdmin) を付与し一般遮断
SEC-004	状態遷移	決済キャンセル時の手紙誤開示防止	高	解決済	クイズ正解時は未解決維持、決済時のみ開示
SEC-005	安全防衛	電話番号・LINE ID・メアド直接記載すり抜け防止	高	解決済	全角・記号正規化+多重正規表現フィルター
SEC-006	決済保全	同一手紙に対する二重決済・多重課金防止	中	解決済	完了Tx検出時は追加課金なしで再返却
SEC-007	決済保全	eKYC不合格時の返金台帳連携と未返金アラート	中	解決済	不合格時返金台帳自動同期・管理アラート
SEC-008	認証	パスワードリセットトークンの使い捨て・失効	中	解決済	30分期限切れ・使用后即時NULLクリア
SEC-009	認可・権限	一般ユーザーの管理者API (/admin/*) アクセス遮断	高	解決済	RBACミドルウェアによる厳格アクセス拒否
SEC-010	認可・権限	プロフィール更新APIでのロール書き換え防止	高	解決済	role, ekyc_verifiedの自己更新を遮断

ID	カテゴリ	点検・監査項目	リスク	判定	対策・解決内容
SEC-011	個人情報保護	退会時における認証情報・個人データの物理消去	中	解決済	外部キー匿名化後、usersテーブルから物理削除
SEC-012	DoS防御	ログイン・会員登録・投稿・検索APIレート制限	中	解決済	スロットリング型アクセス頻度制限の導入
SEC-013	Web脆弱性	投稿テキスト・宛名描画時のXSS無害化	高	解決済	HTMLタグ・スクリプトの自動エスケープ
SEC-014	個人情報保護	削除申請者情報の秘匿性確保	中	解決済	第三者閲覧完全遮断・管理者専用化
SEC-015	個人情報保護	通報ログ (reports) の第三者閲覧遮断	中	解決済	認可ミドルウェアによる保護
SEC-016	個人情報保護	eKYC身分証原本の非蓄積・即時破棄ポリシー	高	解決済	生画像をDB保存せず認証日時のみ保持
SEC-017	IDOR防止	他人のメッセージログID改変閲覧防止	高	解決済	送受信者本人のみ閲覧許可に厳格化
SEC-018	SEO保護	メタタグ・JSON-LDへの機微本文非混入	低	解決済	動的メタタグから手紙本文・本名を除外
SEC-019	総当たり防御	手紙単位でのクイズ誤答ロック (分散攻撃防御)	高	解決済	単一IP 5回で24h、分散計15回で30分凍結
SEC-020	なりすまし防止	eKYC承認後の本名・生年月日改ざんロック	高	解決済	認証済みアカウントの氏名更新を禁止
SEC-021	ファイル保護	添付画像形式の厳格検証 & SVGスクリプト遮断	高	解決済	Base64 MIME検証でSVG・HTMLを排除
SEC-022	ヘッダー防御	セキュリティHTTPヘッダー導入 (クリックジャッキング)	中	解決済	X-Frame-Options: SAMEORIGIN等適用
SEC-023	ログ保護	監査ログへの機微情報非混入 (PIIマスキング)	中	解決済	16桁カード番号・パスワードの自動マスク
SEC-024	セッション	退会時トークンの即時失効 (DBリアルタイム照合)	高	解決済	退会済みJWTトークンを即座に401拒否
SEC-025	決済セキュリティ	Stripe Webhook暗号署名の厳格検証	高	解決済	署名なし不正コールバックの遮断
SEC-026	アカウント管理	BAN (凍結) ユーザーのリアルタイム強制キック	高	解決済	is_blocked=1のアカウントを全APIで403遮断



2. Web画面配信 & E2E自動疎通テスト (全27項目 PASS)

番号	テスト項目	ステータス	検証詳細
Page 01-10	主要10画面のSPA配信 (Home, Create, Search, Admin, FAQ等)	10/10 PASS	Status 200 OK & レンダリング確認
Header 01-03	セキュリティHTTPヘッダー (X-Frame-Options, nosniff等)	3/3 PASS	SAMEORIGIN / nosniff / strict-origin
E2E 01-02	差出人ユーザーA 新規登録 & JWT発行	PASS	201 Created & ログイン成功
E2E 03	思い出の手紙投函 (2問クイズ・連絡先付き)	PASS	Post ID生成 & DB格納
E2E 04	未ログイン/第三者閲覧時の本文・クイズ正解・連絡先の完全非送出	PASS	カンニング・漏洩の物理遮断確認
E2E 05-06	受取人ユーザーB 新規登録 & ログイン	PASS	独立JWTトークン発行確認
E2E 07-08	クイズ誤答判定 (401) & 正解判定 (quizPassed: true)	PASS	正解時も決済前は手紙未解決維持
E2E 09-10	1,200円 Stripe決済完了 → 手紙本文・LINE ID開示	PASS	決済成功と同時に安全に開示
E2E 11	同一手紙に対する二重決済・多重課金防止	PASS	alreadyUnlocked: true で情報再返却
E2E 12	解決後の無関係な第三者アクセス時の完全秘匿	PASS	第三者へは本文・連絡先を完全遮断
E2E 13-14	受取人ユーザーB 退会処理 & トークン即時401失効	PASS	物理データ消去 & トークン無効化



3. 本番マスター包括監査 (全14項目 PASS)

ステップ	監査項目	ステータス	検証詳細
Step 1 (4項目)	本番データ初期化&Seeding (手紙50件、体験談8件、NGワード73語)	4/4 PASS	初期化・再展開の完全整合性
Step 2 (3項目)	高負荷・DoS耐性 (10並行ログイン、15並行検索、総当たりロック)	3/3 PASS	高負荷時のサーバー非クラッシュ実証
Step 3 (4項目)	警察照会ログ出力 (刑法197条)、通報台帳、削除申請、売上統計	4/4 PASS	令状照会データの一括自動出力実証
Step 4 (3項目)	本番DB互換、Stripe Webhook署名検証、監査ログPIIマスキング	3/3 PASS	偽装コールバック防御・ログ安全化



4. 本番デプロイ・運営開始 17大マスターチェックリスト

分類	項目	適合判定	システム対応状況
A. インフラ	1. RDBMS / 2. DATABASE_URL / 3. マイグレーション	3/3 適合	PostgreSQL/SQLite自動切替&自動適用
B. API・決済	4. Gemini商用キー / 5. Resend配信 / 6. Stripe Webhook	3/3 適合	AI自律検閲、リッチHTMLメール、署名検証
C. データ管理	7. テストデータ初期化 / 8. サンプルSeeding	2/2 適合	管理者ワンクリック初期化・全国データ展開

分類	項目	適合判定	システム対応状況
D. SNS認証	9. LINE/Googleクライアント / 10. 認証環境変数	2/2 適合	OAuthリダイレクトフロー&.env.example
E. 法務・規約	11. 利用規約 / 12. PP / 13. 特商法 / 14. 制定日統一	4/4 適合	制定日 2026年8月15日 統一、1200円表記
F. 運用防衛	15. 自動バックアップ / 16. APIレート制限	2/2 適合	マネージドDB対応、全域アクセス制限
G. 最終テスト	17. eKYC・Stripe決済・退会物理消去の最終疎通	1/1 適合	全41項目統合テスト完全合格

🌟

5. サービス発展・拡張機能（全4項目 実装完了）

機能	実装ファイル	ステータス	効果・メリット
1. PWA スマホアプリ化	public/manifest.json, public/sw.js	実装完了	ホーム画面追加・全画面起動・オフラインキャッシュ
2. SEO & SNS最適化	public/robots.txt, public/sitemap.xml, index.html	実装完了	Googleインデックス促進・X/LINE OGPカード
3. リッチHTMLメール	server.ts (renderRichEmailHtml)	実装完了	カード型レスポンスHTML通知・本人確認メール
4. 多言語対応 (i18n)	src/contexts/LanguageContext.tsx	実装完了	JP / EN 言語切替トグル・翻訳基盤

本報告書は、ReMEETs 自動品質保証システムにより 2026年9月4日 に生成・認証されました。

© 2026 ReMEETs 事務局（サービス制定日: 2026年8月15日）